Appendix J — Technology Architecture

Prepared by the founders — Yusuf Quadri (CEO) and Yusuff Adeagbo (CTO), who designed and built the architecture described below.

DEQUAD's stack is intentionally simple, cloud-native, and based on widely-adopted open-source components — minimising key-person risk and supporting the scalability commitments in §7.

J.1 High-level architecture diagram

```
                   ┌──────────────────────────┐
                  │  Cloudflare (DNS, WAF)  │
                  └────────────┬─────────────┘
                               │ TLS 1.3
         ┌─────────────────────┴─────────────────────────────
         │                                         │
     ┌───▼───────────┐                     ┌────────▼────────┐
     │  Web client   │                     │  Native clients │
     │  (React +     │                     │  (iOS / Android │
     │   Expo Router)│                     │   via Expo /    │
     │               │                     │   EAS Build)    │
     └───────┬───────┘                     └────────┬────────┘
         │                                         │
         │             HTTPS (Bearer-token auth, JSON)          │
         └─────────────────────┬───────────────────────────────
                           │
                  ┌────────▼────────┐
                  │  Ingress        │
                  │ (Nginx, K8s)    │
                  └────────┬────────┘
                           │
                  ┌────────▼────────┐
                  │ FastAPI API     │
                  │ (Python 3.11)   │
                  │ - Auth          │
                  │ - Matching      │
                  │ - Mood          │
                  │ - Safeguarding  │
                  │ - Support       │
                  │ - Admin         │
                  └──┬─────┬─────┬──┘
                     │     │     │
      ┌──────────────┘     │     └──────────────────┐
      │                    │                        │
   ┌──▼──────────┐   ┌─────▼────────┐    ┌──────────▼───────┐   ┌────────▼──────
   │ MongoDB Atlas│  │ Stripe Connect│   │ Outbound services│
   │ (UK region, │   │ (UK FCA-     │    │ - SMTP (Gmail/   │
   │  replicated)│   │  regulated)  │    │   AWS SES)       │
   │             │   │              │    │ - Expo Push      │
   │ Collections:│   │ Subscriptions│    │ - Sentry         │
```

```
       │  - users       │    │  - University      │          │                    │
       │  - matches     │    │  - Premium         │          │                    │
       │  - chat_msgs   │    │                    │          │                    │
       │  - mood        │    └────────────────────┘          └────────────────────┘
       │  - support     │
       │  - sg_alerts   │          ┌────────────────────┐
       │  - reports     │          │  LLM provider      │
       │  - waitlist    │ ◄────────┤ (OpenAI gpt-4o-    │
       └────────────────┘          │   mini for AI      │
                                   │   first-line       │
                                   │   support replies) │
                                   └────────────────────┘
```

J.2 Component table

Layer	Technology	Hosting	Why this choice
DNS / WAF / DDoS	Cloudflare	Global	Industry-standard, UK regulatory comfort
CDN	Cloudflare	Global edge	Reduces latency for image / static assets
Ingress	Nginx (managed)	Kubernetes (UK)	Battle-tested, no exotic dependencies
API	FastAPI on Python 3.11	Kubernetes (UK)	Strong typing, async I/O, high developer velocity
Database	MongoDB Atlas, **UK region**	Managed	Flexible schema for evolving wellbeing data; UK data residency by default
Search / aggregation	MongoDB aggregation pipeline	Managed	Avoids extra dependency; sufficient at projected scale
Auth	OAuth 2.0 (university SSO partnerships, Y2+) and Bearer tokens for native	Managed	No password reuse; FA-protected admin route
Payments	Stripe (UK entity)	Managed	FCA-regulated; PCI-DSS handled by Stripe
File storage	Cloudflare R2 (S3-compatible, UK)	Managed	Cost-effective; user-uploaded photos
Email	Gmail SMTP relay (pre-pilot) → AWS SES, eu-west-2 (production)	Managed	Auditable delivery
Push notifications	Expo Push Service	Managed	Single API for iOS + Android
Observability	Sentry (UK data residency option) + structured logs to CloudWatch (eu-west-2)	Managed	Proactive issue detection; SLO dashboards
LLM provider	OpenAI gpt-4o-mini via Emergent LLM Key	API	Used only for AI auto-reply to support messages; no user-identifiable PII in prompts

J.3 Data residency

All Personally Identifiable Information (PII) and Special Category Data (mental-health, mood entries) is stored in MongoDB Atlas's **UK region** (London). No PII leaves the UK except: - Stripe (UK entity; Stripe stores card tokens, not card numbers, in compliance with PCI-DSS Service Provider Level 1). - OpenAI inference calls (only contain redacted, non-PII excerpts of support messages — see DPIA Appendix E §4.3).

J.4 Security controls implemented

Control	Implementation	Standard
TLS in transit	All endpoints TLS 1.3, HSTS preload	NCSC guidance
Encryption at rest	MongoDB Atlas AES-256	NCSC guidance
Secret management	Environment variables sealed via Emergent vault; never in source	OWASP ASVS L2
Auth	Bearer tokens, 7-day expiry, refresh on use	OWASP ASVS L2
Rate limiting	`RateLimitMiddleware` on the API gateway (per-IP + per-user)	OWASP ASVS L2
Audit logging	Structured logs to centralised store; safeguarding events retained 7 years	UK DPA 2018
Backups	Daily MongoDB Atlas snapshots, 30-day retention; quarterly restore drills	NCSC Cloud Security Principles
Vulnerability scanning	Dependabot + weekly OWASP ZAP scan	NCSC Cloud Security
Penetration testing	Annual external pen-test (Y1 onward) by CREST-approved firm	Cyber Essentials Plus requirement

J.5 Scalability headroom

Component	Current capacity	Capacity at 1M users	Mitigation if exceeded
FastAPI pods	2 pods × 0.5 CPU	Auto-scale to 40 pods	Kubernetes HPA already configured
MongoDB Atlas	M10 cluster (~5GB)	M50 cluster (~600GB)	Atlas vertical scaling, no downtime
Push (Expo)	200k/day	Unlimited (Expo Pricing)	n/a
Email	10k/day (Gmail)	Migrate to AWS SES at 50k/day	Already designed
LLM calls	Soft cap by Emergent LLM Key budget	Move to direct OpenAI org account	One-line config change

J.6 Disaster-recovery RTO / RPO

Scenario	Recovery Time Objective	Recovery Point Objective
Single-pod failure	< 30 seconds	0
Region failure (London)	< 4 hours	< 24 hours
Database corruption	< 4 hours	< 24 hours
Total data loss	< 24 hours	< 24 hours

A documented runbook is maintained in `/app/backend/scripts/RUNBOOK.md`.

J.7 Roadmap items not yet built

Item	Target quarter	Notes
University SSO (Shibboleth / SAML)	Q2 Year 1	Required for some Russell Group integrations
Anonymised analytics export to partner DSLs	Q3 Year 1	Aggregate, no individual data
ISO 27001 controls hardening	Year 3	Required for NHS DSPT alignment
End-to-end encrypted DMs (Signal protocol)	Year 2	Safeguarding compatibility under evaluation

This appendix is a current-state and forward-looking architecture summary as at the date of submission. Material architecture changes will be communicated to UKES at the standard 6/12/24-month contact points.